

Vorlesung Cybersicherheit, Sommersemester 2025

Sicherheitsprotokolle und Schlüsselvereinbarung

Prof. Dr.-Ing. Lucas Vincenzo Davi
Fakultät für Informatik
Arbeitsgruppe Systemsicherheit <https://www.syssec.wiwi.uni-due.de/>
Universität Duisburg-Essen

© SYSSEC, Prof. Dr. Lucas Davi

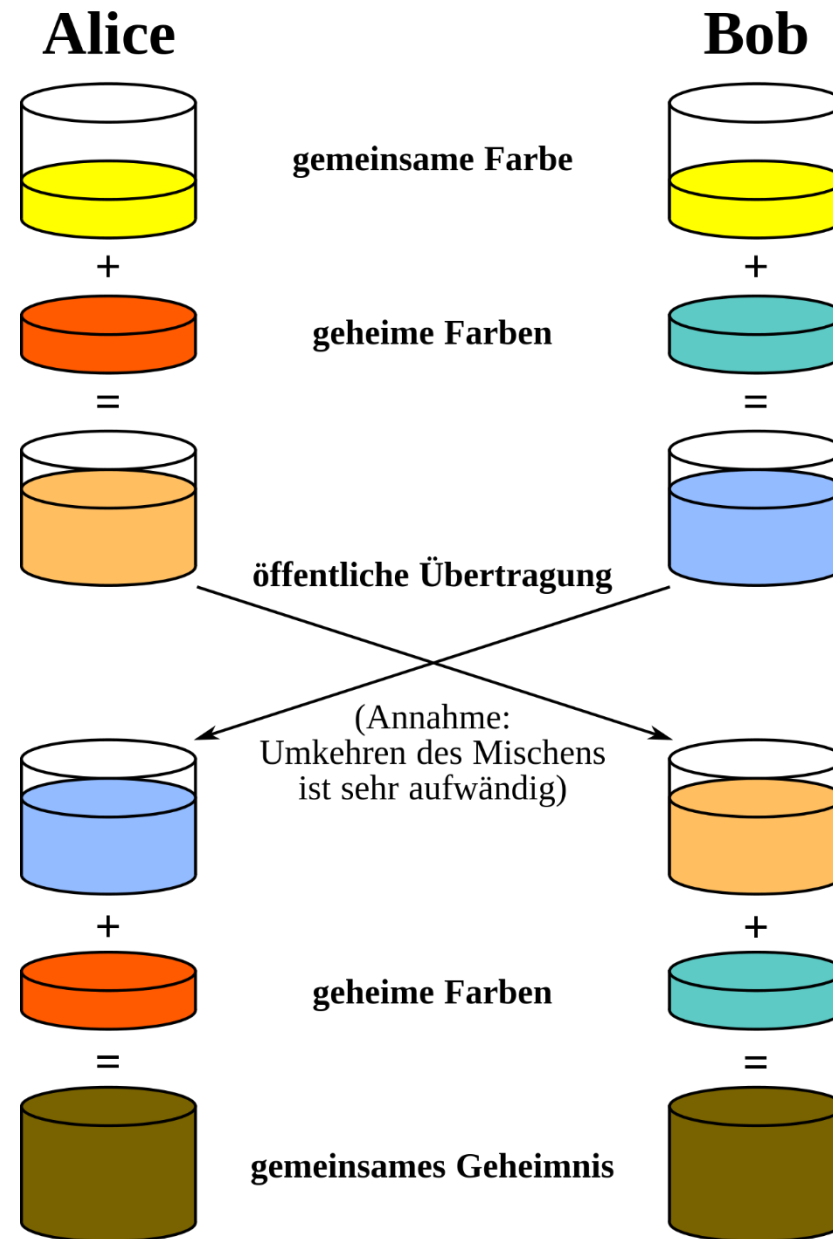
Rückblick und Themen heute

- Rückblick
 - Bitcoin
 - Blockchain
 - Proof-of-Work
- Themen heute
 - Diffie-Hellman Key Exchange
 - Needham-Schroeder Protokoll
 - Kerberos

Schlüsselvereinbarung mit asymmetrischer Kryptografie: Diffie-Hellman Key Exchange

- Wir kennen bereits RSA; asymmetrisches Verfahren welches das Faktorisierungsproblem als Einwegfunktion nutzt
- 1976 stellen Whitfield Diffie und Martin Hellman den Diffie-Hellman Key Exchange (DHKE) vor
 - Dieser nutzt das diskrete Logarithmusproblem als Einwegfunktion
- DHKE bietet eine praktische Lösung für das Schlüsselverteilungsproblem
 - Heute wird DHKE in SSL, TLS und IPsec genutzt
- 9. Mai 2023
 - ACM ByteCast Podcast mit W. Diffie und M. Hellmann [[Link](#)]

Veranschaulichung des Protokolls



Quelle: <https://de.wikipedia.org/wiki/Diffie-Hellman-Schl%C3%BCsselaustausch>

Das diskrete Logarithmusproblem

- Primitivwurzel modulo p
- Eine Zahl ist eine Primitivwurzel wenn jedes Element der primen Restklassengruppe als eine ihrer Potenzen dargestellt werden kann

Bsp.: $p=7$ Primitivwurzel $\alpha=3$
 $x=1 \dots 6$

$$3^x \equiv y \pmod{7}$$

$$3^1 \equiv 3 \pmod{7}$$

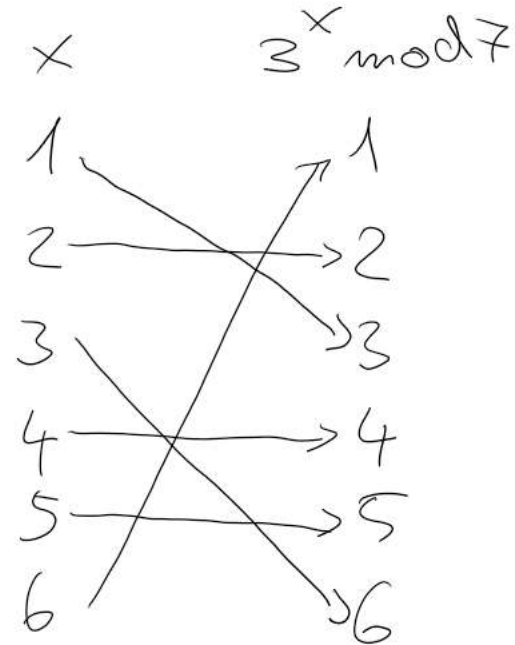
$$3^2 \equiv 2 \pmod{7}$$

$$3^3 \equiv 6 \pmod{7}$$

$$3^4 \equiv 4 \pmod{7} \quad (81)$$

$$3^5 \equiv 5 \pmod{7} \quad (243)$$

$$3^6 \equiv 1 \pmod{7} \quad (729)$$



→ Konsequenz: $y = 3^x \bmod 7$ kann für beliebige y -Werte gelöst werden
 x ist hierbei der diskrete Logarithmus von $y \bmod 7$
Für große Zahlen kann x nicht einfach bestimmt werden (2048 Bit)

1. Wähle große Primzahl p (idealerweise > 2048 Bit)
2. Wähle eine ganze Zahl $\alpha \in (2, 3, \dots, p - 2)$
3. Veröffentliche α und p

Diffie-Hellman-Schlüsselaustausch

Alice α, p öffentl.

Wähle $a \in \mathbb{Z}_p, a \in \{2, 3, \dots, p-2\}$

Berechne:

$$A = \mathbb{Z}_{\text{pub, Alice}} = \alpha^a \bmod p$$

$\xrightarrow{A}$

$\xleftarrow{B}$

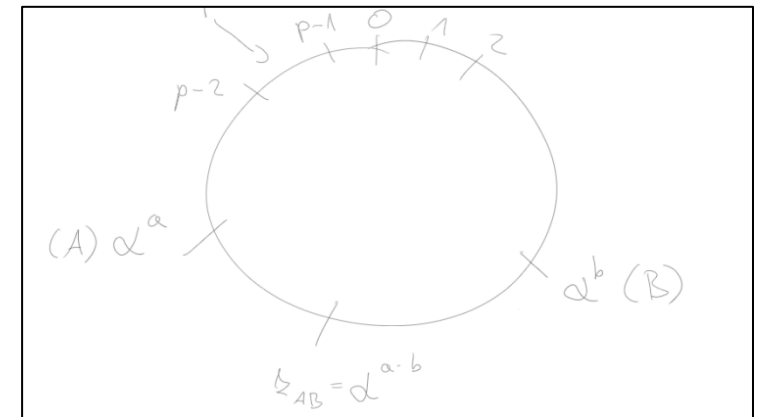
$$\mathbb{Z}_{AB} = B^a \bmod p = \mathbb{Z}_{AB} = A^b \bmod p$$

Bob

Wähle $b \in \mathbb{Z}_p, b \in \{2, 3, \dots, p-2\}$

Berechne:

$$B = \mathbb{Z}_{\text{pub, Bob}} = \alpha^b \bmod p$$



Berechnung des Sitzungsschlüssel k_{AB} durch Alice:

- $B^a \equiv (\alpha^b)^a \equiv \alpha^{ab} \text{ mod } p$

Berechnung des Sitzungsschlüssel k_{AB} durch Bob:

- $A^b \equiv (\alpha^a)^b \equiv \alpha^{ab} \text{ mod } p$

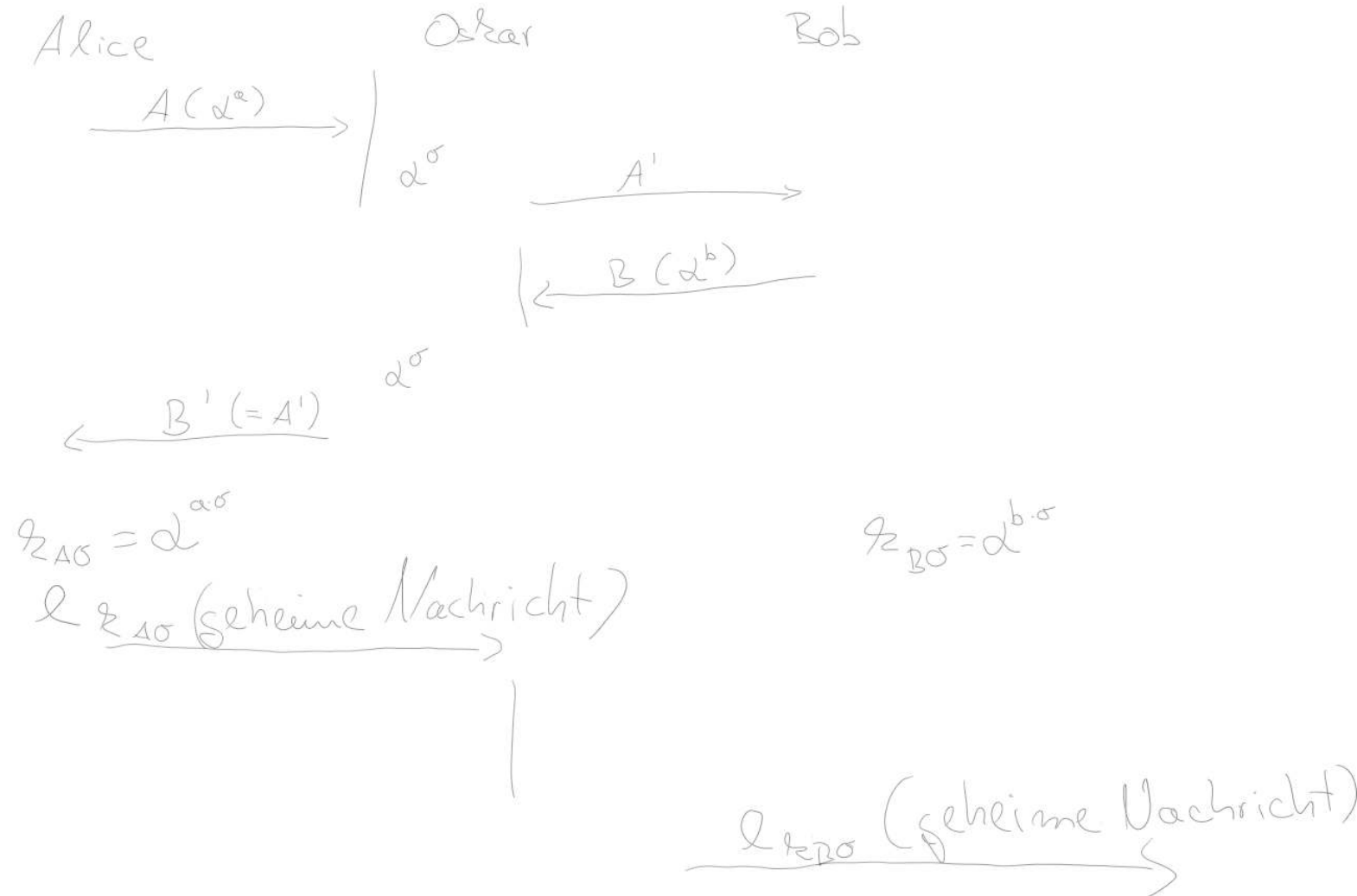
Beide, Alice und Bob haben den gleichen Sitzungsschlüssel:

- $k_{AB} \equiv \alpha^{ab} \text{ mod } p$

Beachte:

- Wie alle asymmetrischen Verfahren, kann DHKE ohne Zertifikate von einem aktiven Angreifer mittels Man-In-The-Middle Angriff angegriffen werden

MITM Angriff gegen DHKE



Beobachtungen

Alice:
 $a = 1$?

$$a^1 \bmod p = a = A$$

$$a = p - 1$$

$$a^{p-1} \bmod p = 1 \quad (\text{kleine Fermatsche Theorem})$$

$$\Rightarrow A = 1$$

Beispiel für DHKE (1)

Beispiel: $p = 29$, $\alpha = 2$

Alice

$$a = 5$$

$$\begin{aligned} A &= \alpha^a \bmod p = 2^5 \bmod 29 \\ &= 2^4 \cdot 2 \\ &= 16 \cdot 2 \\ &= 32 \bmod 29 \\ &\equiv 3 \bmod 29 \end{aligned}$$

$$A = 3$$

Bob

$$b = 12$$

$$\begin{aligned} B &= 2^b \bmod 29 \\ &= (2^6)^2 \bmod 29 \\ &= (64)^2 \bmod 29 \\ &\equiv (6)^2 \bmod 29 \\ &\equiv 7 \bmod 29 \end{aligned}$$

$$B = 7$$

Beispiel für DHKE (2)

$$z_{AB} = B^a \mod p$$
$$= 7^5 \mod 29$$

$$= 7^2 \cdot 7^2 \cdot 7 \mod 29$$

$$= 49 \cdot 49 \cdot 7 \mod 29$$

$$= 20 \cdot 20 \cdot 7 = 2800 \quad (96 \cdot 29, \text{Rest: } 16)$$

$$\equiv 16 \mod 29$$

$$z_{AB} = A^b \mod p$$
$$= 3^{12} \mod 29$$
$$= 16$$

Schlüsselvereinbarung mit symmetrischer Kryptografie

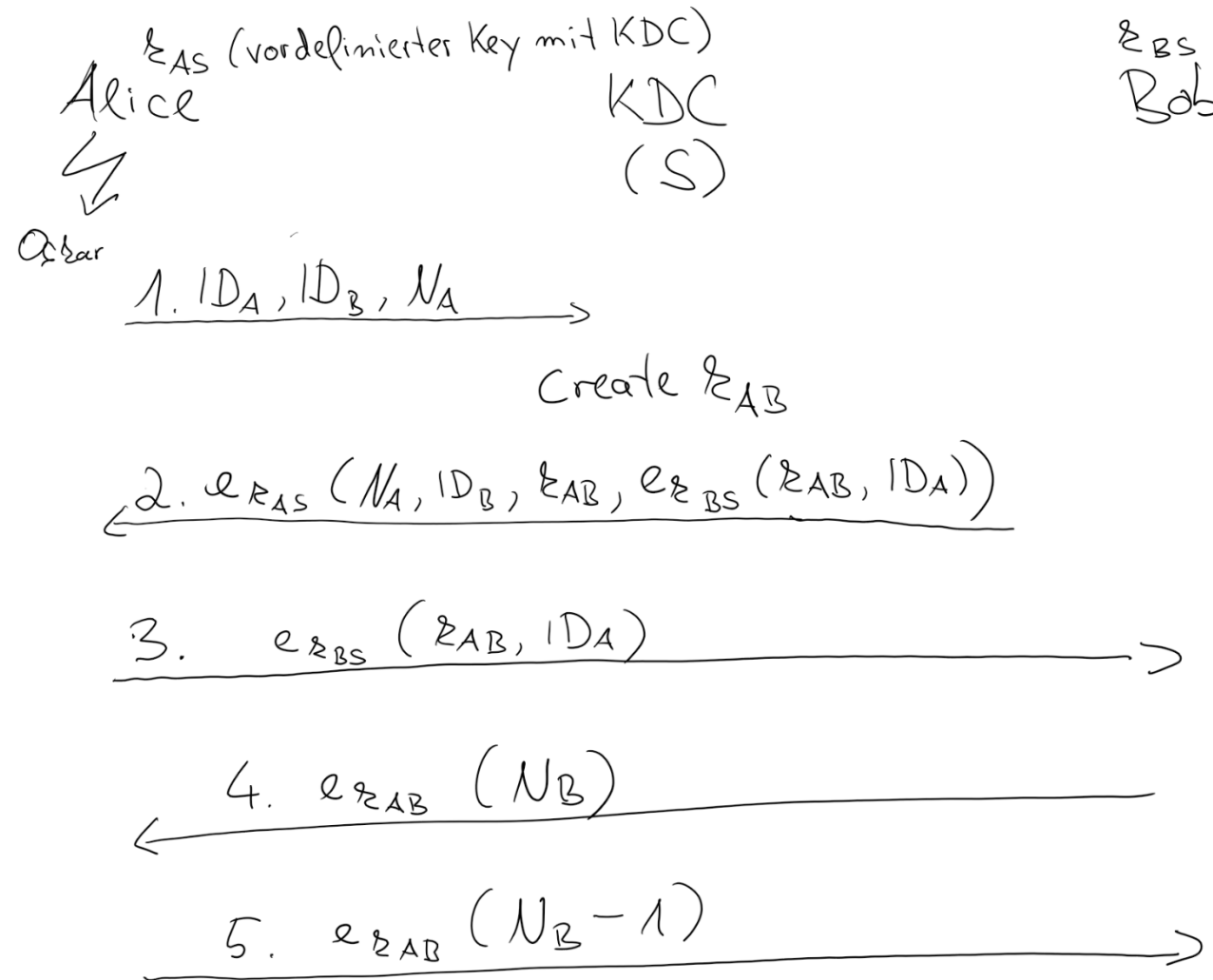
Auch mit symmetrischer Kryptografie können geheime Sitzungsschlüssel (Session-Keys oder Ephemeral-Keys) ausgetauscht werden

- Kurzzeitige Sitzungsschlüssel sind hilfreich:
 - Wenige Chifftrate stehen dem Angreifer zur Verfügung
 - Angreifer muss mehrere Schlüssel entdecken, um lange Nachrichten zu entschlüsseln (Beispiel: Satellitenfernsehen, Sprachverschlüsselung)
- Etablierung von Sitzungsschlüsseln mit symmetrischer Kryptografie ist rechentechnisch gesehen schneller

- Die folgenden Protokolle nutzen einen Schlüsselserver; das KDC – Key Distribution Center
- Annahme:
 - Jeder Nutzer besitzt einen geheimen symmetrischen Schlüssel mit dem KDC
 - Dieser muss vorab installiert worden sein (z.B. durch den Systemadministrator bei Laptop Übergabe)
- Das KDC erzeugt Sitzungsschlüssel und verteilt diese an die Teilnehmer

- Replay Angriffe
 - Ist der empfangene Sitzungsschlüssel aktuell?
 - Wenn nicht, kann der Angreifer so tun als sei er das KDC
 - Dafür verschickt er die alten verschlüsselten Nachrichten an Alice und Bob
 - Lösung: Sorge für „Freshness“ durch Nonces (Zufallswerte), Timestamps, Counter
- Schlüsselbestätigungsangriffe
 - Wurde der Sitzungsschlüssel von der gegenüberliegenden Partei bestätigt?
 - Wenn nicht, kann Oskar eine Identität (Alice oder Bob) austauschen und durch seine Identität ersetzen
 - Somit wird ein Sitzungsschlüssel erzeugt, den auch Oskar kennt
 - Lösung: Challenge-Response-Verfahren und Einbindung der Identitäten

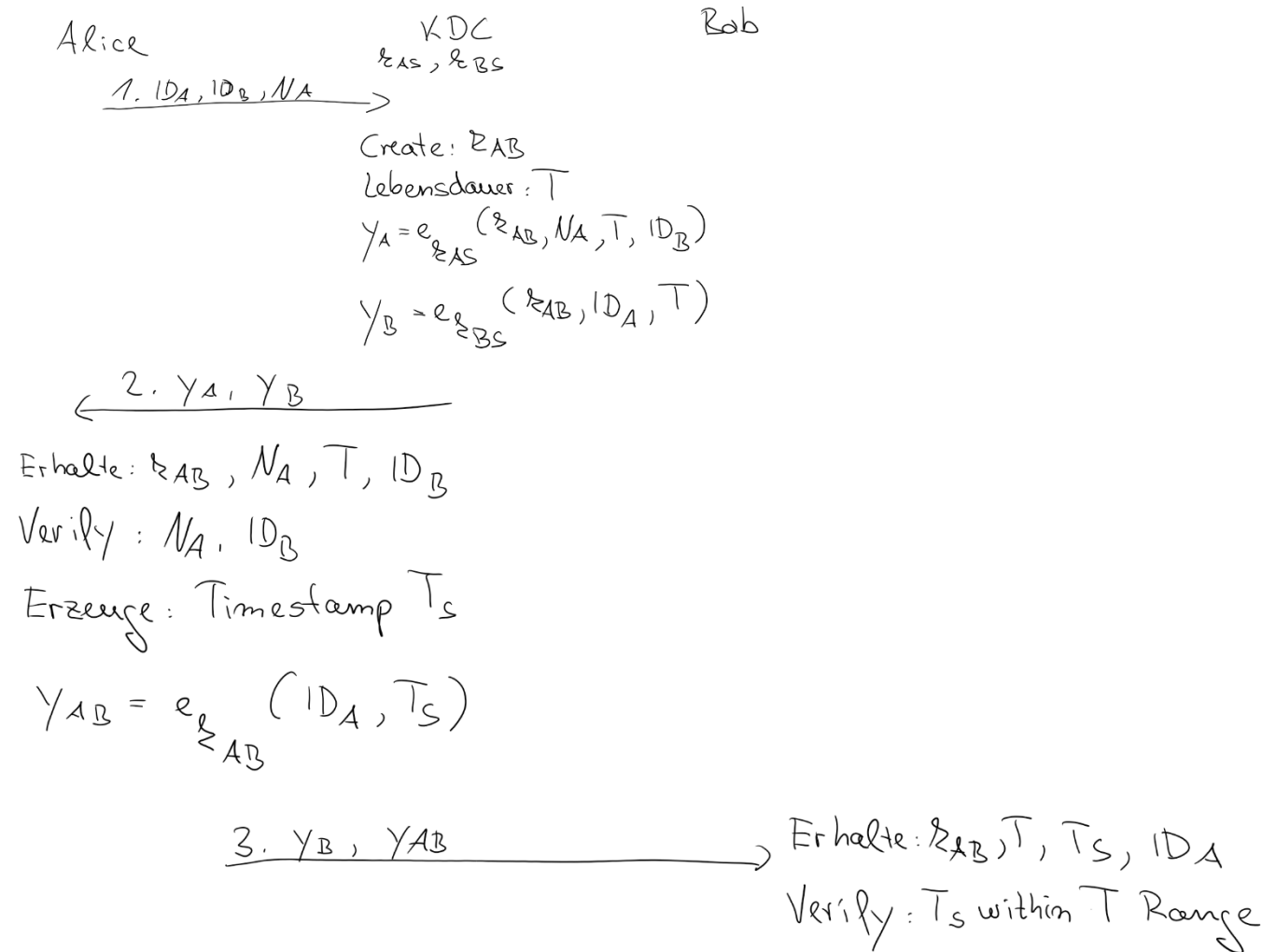
Das Needham-Schroeder Protokoll von 1978



- Schlüsselbestätigungsangriffe
 - Nicht möglich, da die Identitäten in Nachricht 2 verschlüsselt jeweils an Alice und Bob verschickt werden
 - Nachricht 4 und 5 bestätigen Bob, dass Alice den Sitzungsschlüssel besitzt. Dies wird mittels Challenge-Response-Verfahren erreicht
- Replay-Angriffe
 - Nonces garantieren Freshness und verhindern das Senden von alten Nachrichten
 - ABER was passiert wenn das Protokoll nach Nachricht 2 abgebrochen wird?
 - Ein Angreifer, der den Key von Alice geknackt hat, kann dann einfach Nachricht 3 senden
 - An dieser Stelle merkt Bob nicht, dass es sich um einen alten Sitzungsschlüssel handelt
 - Besser wären hier Timestamps

- Kerberos basiert auf dem Needham-Schroeder Protokoll
- Es ist aber mehr als nur ein Schlüsseltransportprotokoll, da es im Wesentlichen Authentisierung von Benutzern im Netzwerk durchführt
- Kerberos wurde 1993 im [RFC 1510](#) standardisiert
- Weit verbreitet in Active Directory Implementierungen (Windows und Linux)

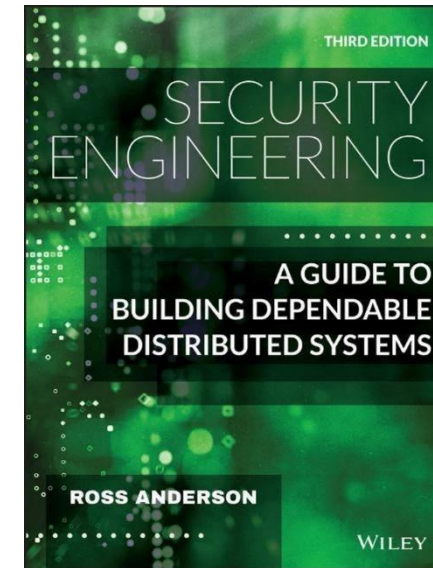
Vereinfachte Variante des Kerberos Protokolls



- Im Gegensatz zum Needham-Schroeder-Protokoll werden Timestamps genutzt
 - Somit ist der zuvor besprochene Angriff nicht möglich
- Aber Timestamps erfordern synchronisierte Uhren
- Sowohl Kerberos als auch Needham-Schroeder nehmen eine „trusted third-party“ (KDC) an
 - Nachteil: Single-Point-of-Failure

Referenzen

- Die Vorlesungsfolien für dieses Thema sind auf Basis des Buches „Kryptografie verständlich“ von C. Paar und J. Pelzl sowie dem Buch „Security Engineering“ von R. Anderson entstanden
- Es gibt ebenfalls eine dazugehörige Vorlesungsreihe „Einführung in die Kryptografie“ von C. Paar auf YouTube:
<https://www.youtube.com/channel/UCuJu8DOJLMltMt8RcX1tdBw/videos>



Vorlesung Cybersicherheit, Sommersemester 2024

Vielen Dank für Ihre Aufmerksamkeit

Prof. Dr.-Ing. Lucas Vincenzo Davi
Fakultät für Informatik
Arbeitsgruppe Systemsicherheit
Universität Duisburg-Essen

© SYSSEC, Prof. Dr. Lucas Davi